https://www.exploit-db.com/exploits/52484

1. ¿Qué busca el código? (El Objetivo)

El código busca tomar el control del flujo de ejecución de una aplicación llamada Easy File Sharing Web Server v7.2 que corre sobre Windows.

Específicamente, busca un punto de entrada en el protocolo HTTP. El servidor web no valida correctamente la longitud de los datos que recibe en la "Cookie" de una petición web. El script envía una cadena de texto masiva (la variable buf) dentro del campo UserID de la cookie.

2. ¿Qué tipo de exposición detecta? (La Vulnerabilidad)

Detecta una vulnerabilidad de corrupción de memoria conocida como Stack-based Buffer Overflow

Este script es un ejemplo de un exploit de desbordamiento de búfer (Buffer Overflow) diseñado para una aplicación específica. A continuación, desgloso los puntos que solicitaste para ayudarte a entender su funcionamiento desde una perspectiva técnica y educativa.

3. ¿En qué categoría está? (Clasificación)

Advisories and Vulnerabilities → Reportes de vulnerabilidades

https://www.exploit-db.com/exploits/52485

1. ¿Qué busca el código?

El script busca automatizar un ataque de suplantación de identidad en el flujo de restablecimiento de contraseña. Su objetivo es engañar al servidor de correo (Mailcow) para que envíe un correo electrónico de recuperación cuyo enlace apunte al servidor del atacante en lugar de al servidor legítimo.

El mecanismo: Cuando solicitas un cambio de contraseña, el servidor genera un correo. Si el servidor usa la cabecera Host de la petición HTTP para construir ese enlace y no la tiene "hardcodeada" o validada, el atacante puede cambiarla por attacker.com.

La captura: El script levanta un servidor HTTPS local (ListenerState) que se queda "escuchando". Si la víctima hace clic en el enlace envenenado que llegó a su correo, el token secreto de recuperación se envía directamente al servidor del atacante, quien luego puede usarlo para cambiar la contraseña de la víctima.

2. ¿Qué tipo de exposición detecta?

Este código detecta y explota una falla de lógica en el manejo de cabeceras HTTP y una vulnerabilidad de inyección. Específicamente detecta:

Confianza implícita en entradas del usuario: El servidor confía en la cabecera Host enviada por el cliente

para generar contenido crítico (el enlace de reset).

Riesgo de Account Takeover (ATO): La exposición no es solo de información, sino de control total de la cuenta. Al capturar el token, el atacante tiene las llaves para entrar a cualquier cuenta de correo del sistema.

Bypass de protecciones de red: Como el correo electrónico proviene del servidor legítimo de Mailcow, pasa los filtros de SPAM y las protecciones SPF/DKIM, lo que lo hace un ataque de phishing casi perfecto.

3. ¿En qué categoría está?

Advisories and Vulnerabilities → Reportes de vulnerabilidades

Al igual que el ejemplo anterior, este script es un exploit de día-X documentado. Es una herramienta diseñada para probar una vulnerabilidad específica que ya tiene un identificador (CVE).

https://www.exploit-db.com/exploits/52478

1. ¿Qué busca el código?

El script busca crear un archivo con la extensión .library-ms (un archivo de descripción de biblioteca de Windows) que contiene una ruta de red maliciosa (UNC path).

El Gancho: Cuando un usuario de Windows abre o importa este archivo, el Explorador de Archivos intenta "conectar" con la ubicación especificada para mostrar el contenido de la biblioteca.

La Trampa: El script configura esa ubicación para que apunte a la dirección IP del atacante (ej. \\192.168.1.162\shared).

El Resultado: Al intentar conectar, Windows inicia automáticamente un proceso de autenticación.

2. ¿Qué tipo de exposición detecta?

Detecta una vulnerabilidad de Divulgación de Información (Information Disclosure), específicamente la exposición de Hashes NTLM.

Fuga de Credenciales: Cuando Windows intenta acceder a una ruta de red (SMB), envía por defecto el nombre de usuario y el hash NTLMv2 de la sesión actual para intentar autenticarse.

Captura de Hash: El atacante, usando herramientas como Responder o Metasploit, recibe ese hash. Aunque no es la contraseña en texto plano, el atacante puede:

Crackearlo: Intentar descifrarlo fuera de línea usando diccionarios de contraseñas.

NTLM Relay: Reenviar ese hash a otro servidor de la misma red para ganar acceso sin siquiera saber la

contraseña.

Suplantación (Spoofing): El archivo parece un elemento inofensivo del sistema, lo que facilita el engaño.

3. ¿En qué categoría está?

Advisories and Vulnerabilities

Es un PoC (Prueba de Concepto) para el CVE-2025-24054. Documenta cómo una funcionalidad de bibliotecas de Windows puede ser convertida en un vector de ataque.